

Cyber Attack Kill Chain



Ali
Ali

Digitally signed
by Ali Ali
DN: c=LB,
st=Beirut, l=AA,
o=MISC, ou=ISC,
cn=Ali Ali
Date: 2024.08.30
11:10:23 +03'00'



Cyber Attack

(Kill Chain)

Intro

- ❑ **Why is it important to understand how the Cyber Kill Chain works?**
- *The Cyber Kill Chain is a crucial framework for understanding and protecting against various cyber threats, including ransomware attacks, security breaches, and Advanced Persistent Threats (APTs)*
- *By leveraging the Cyber Kill Chain, you can assess your network and system security, identify missing security controls, and close security gaps based on your company's infrastructure*
- *Understanding the Kill Chain is essential for roles such as SOC Analyst, Security Researcher, Threat Hunter, or Incident Responder*

Cyber Attack

(Kill Chain)

Intro

- *It enables you to recognize intrusion attempts and comprehend the intruder's goals and objectives*
- *This model covers the following stages:*
 1. *Reconnaissance*
 2. *Weaponization*
 3. *Delivery*
 4. *Exploitation*
 5. *Installation*
 6. *Command & Control*
 7. *Actions on Objectives*

1. Reconnaissance

- *Definition:*
 - *This is the initial phase where the attacker gathers information about the target*
 - *This can include identifying potential vulnerabilities, understanding the network architecture, and collecting data on employees*
- *Example:* *An attacker might use open-source intelligence (OSINT) tools to find email addresses of employees or scan the target's network for open ports and services*

Cyber Attack

(Kill Chain)

Reconnaissance

- *Technical Details:*
 - *Reconnaissance is a critical phase in the Cyber Kill Chain, as it sets the foundation for the subsequent stages of an attack*
 - *During this phase, attackers aim to gather as much information as possible about their target to identify potential entry points and vulnerabilities*
 - ***This phase can be divided into two main types:*** *passive and active reconnaissance*

o **Passive Reconnaissance**

In passive reconnaissance, attackers gather information without directly interacting with the target. This helps them avoid detection. Techniques include:

- ✓ *Open-Source Intelligence (OSINT): Collecting publicly available information from sources like social media, websites, and public records*
- ✓ *WHOIS Lookup: Gathering information about domain ownership and registration details*
- ✓ *DNS Enumeration: Identifying domain names and associated IP addresses*



- ✓ *Social Engineering: Gathering information by manipulating individuals into divulging confidential information*

○ **Active Reconnaissance**

In active reconnaissance, attackers interact directly with the target to gather information. This can be riskier as it increases the chances of detection. Techniques include:

- ✓ *Network Scanning: Using tools to scan the target's network for open ports, services, and vulnerabilities*
- ✓ *Ping Sweeps: Sending ICMP echo requests to identify active hosts on a network*

Cyber Attack

(Kill Chain)

Reconnaissance

- ✓ *Banner Grabbing: Capturing information from service banners to identify software versions and potential vulnerabilities*
- ✓ *Vulnerability Scanning: Using automated tools to identify known vulnerabilities in the target's systems*
- ✓ *Example: An attacker might use a network scanner to identify open ports and services running on the target's network*

- *Tools Used in Reconnaissance*

- *Passive Reconnaissance Tools*

- *Maltego: A powerful OSINT tool that helps visualize relationships between people, companies, domains, and other entities*
- *Shodan: A search engine for internet-connected devices, useful for identifying exposed systems and services*
- *Recon-ng: A web reconnaissance framework with modules for gathering information from various sources*
- *theHarvester: A tool for gathering email addresses, subdomains, and other information from public sources*
- *Google Dorks: Advanced search queries to find specific information indexed by search engines*



- *Tools Used in Reconnaissance*
 - *Active Reconnaissance Tools*
 - *Nmap: A network scanning tool used to discover hosts, services, and vulnerabilities on a network*
 - *Nessus: A vulnerability scanner that identifies security issues in systems and applications*
 - *Metasploit: A penetration testing framework that includes tools for scanning and exploiting vulnerabilities*
 - *Nikto: A web server scanner that identifies potential vulnerabilities and misconfigurations*
 - *Netcat: A versatile networking tool used for port scanning, banner grabbing, and other network-related tasks*



Cyber Attack

(Kill Chain)

Weaponization

- *Definition:*

- *In this phase, the attacker creates a deliverable payload using the information gathered during reconnaissance*
- *This often involves combining malware with an exploit to create a weaponized file*

- *Technical Details:*

Weaponization is a critical phase where attackers transform the information gathered during reconnaissance into a functional attack. This phase involves several technical steps:

1. Selection of Exploit:

- *Attackers choose a specific vulnerability to exploit. This could be a software flaw, a misconfiguration, or a zero-day vulnerability*



Ali Ali

- *Example: Selecting a known vulnerability in a PDF reader that allows arbitrary code execution*

2. Development of Malware:

- *Attackers develop or customize malware to exploit the chosen vulnerability. This malware could be a virus, worm, Trojan, or ransomware*
- *Example: Creating a malicious PDF file that, when opened, executes a payload to install a backdoor on the target system*

3. Combining Exploit and Payload:

- *The exploit is combined with the payload (malware) to create a weaponized file. This file is designed to execute the payload when the exploit is triggered*
- *Example: Embedding the exploit code within the PDF file so that opening the file triggers the exploit and executes the payload*

4. Testing the Weaponized File:

- *Attackers test the weaponized file in a controlled environment to ensure it works as intended and remains undetected by security measures*
- *Example: Running the malicious PDF in a sandbox environment to verify that it successfully installs the backdoor without being flagged by antivirus software*

- *Tools Used in Weaponization*

1. Metasploit Framework:

- *A powerful penetration testing tool that includes a wide range of exploits and payloads. It allows attackers to create and test weaponized files*
- *Example: Using Metasploit to generate a malicious PDF file with an embedded exploit*

2. Cobalt Strike:

- *A commercial penetration testing tool that provides advanced threat emulation capabilities. It includes features for creating weaponized payloads and conducting post-exploitation activities*
- *Example: Crafting a weaponized document that delivers a remote access Trojan (RAT)*

3. Veil Framework:

- *A tool designed to generate payloads that bypass antivirus detection. It helps attackers create undetectable malware*
- *Example: Using Veil to create a payload that evades detection by common antivirus solutions*



4. Social-Engineer Toolkit (SET):

- *A framework for automating social engineering attacks. It includes tools for creating phishing emails and malicious attachments*
- *Example: Generating a spear-phishing email with a weaponized attachment using SET*

5. MSFvenom:

- *A payload generator that is part of the Metasploit Framework. It allows attackers to create custom payloads for various platforms*
- *Example: Creating a custom payload that exploits a specific vulnerability in a target application*



Cyber Attack

(Kill Chain)

Delivery

- *Definition:*
 - *The attacker transmits the weaponized payload to the target*
 - *This can be done through various methods such as email attachments, malicious links, or USB drives*
- *Technical Details:*
 - *The Delivery phase is crucial as it involves the actual transmission of the weaponized payload to the target*
 - *The success of this phase depends on the attacker's ability to bypass security measures and entice the target to interact with the payload*

Here are the key technical aspects:

1. Email Attachments:

- ***Spear-Phishing:** Attackers craft personalized emails to specific individuals, making them appear legitimate. These emails often contain malicious attachments or links*
- ***Example:** An attacker sends an email that appears to be from a trusted source, with a malicious PDF attached. When the recipient opens the attachment, the exploit is triggered*

2. Malicious Links:

- *Phishing: Attackers send emails or messages containing links to malicious websites. These websites may host exploit kits or prompt the user to download malicious files*
- *Example: An attacker sends a link to a fake login page. When the user enters their credentials, the attacker captures them, and the page may also deliver a malicious payload*

3. USB Drives:

- *Physical Delivery:* Attackers may leave infected USB drives in public places, hoping that someone will pick them up and plug them into their computer
- *Example:* An attacker drops USB drives in a company's parking lot. When an employee picks one up and connects it to their computer, the malware is executed

4. Web Exploits:

- *Drive-By Downloads:* Attackers compromise legitimate websites or create malicious ones that exploit vulnerabilities in the visitor's browser or plugins
- *Example:* A user visits a compromised website, which automatically exploits a browser vulnerability to download and execute malware

5. Social Engineering:

- *Manipulation*: Attackers use psychological manipulation to trick individuals into performing actions that lead to the delivery of the payload
- *Example*: An attacker calls an employee, pretending to be from the IT department, and convinces them to download and install a "security update" that is actually malware

- *Tools Used in Delivery*

1. Phishing Kits:

- *Description*: Pre-packaged tools that help attackers create and manage phishing campaigns
- *Example*: Gophish is an open-source phishing toolkit designed for security awareness training



2. Exploit Kits:

- *Description: Toolkits that automate the exploitation of vulnerabilities in web browsers and plugins*
- *Example: RIG Exploit Kit is used to deliver various types of malware through drive-by downloads*

3. Email Spoofing Tools:

- *Description: Tools that allow attackers to send emails that appear to come from a trusted source*
- *Example: SPF (Sender Policy Framework) and DKIM (DomainKeys Identified Mail) can be manipulated to bypass email authentication mechanisms*

4. USB Infection Tools:

- *Description: Tools that create malicious USB drives that automatically execute malware when connected*
- *Example: USB Rubber Ducky is a popular tool used to deliver payloads via USB drives*

5. Social Engineering Frameworks:

- *Description: Tools and frameworks that assist in creating and executing social engineering attacks*
- *Example: SET (Social-Engineer Toolkit) is a framework for automating social engineering attacks, including phishing and USB-based attacks*

Cyber Attack

(Kill Chain)

Exploitation

- *Definition:*
 - *Upon delivery, the exploit is triggered, and the attack begins*
 - *This phase involves exploiting a vulnerability to execute the malicious code on the target system*
- *Technical Details:*
 - *The Exploitation phase is where the attacker takes advantage of a vulnerability to execute malicious code on the target system*
 - *This phase is critical as it transitions the attack from a potential threat to an active compromise*

- *Here are the key technical aspects:*

1. Triggering the Exploit:

- *The exploit is triggered when the target interacts with the weaponized payload. This could be opening a malicious file, clicking a link, or connecting an infected USB drive*
- *Example: An employee opens a malicious PDF, triggering the embedded exploit*

2. Executing Malicious Code:

- *Once the exploit is triggered, it executes the malicious code. This code can perform various actions, such as downloading additional malware, creating backdoors, or stealing data*
- *Example: The exploit in the PDF takes advantage of a vulnerability in the PDF reader to execute a payload that installs a remote access Trojan (RAT)*



3. Privilege Escalation:

- *Attackers often seek to escalate their privileges to gain higher-level access to the system. This can involve exploiting additional vulnerabilities to move from a regular user account to an administrator or root account*
- *Example: The initial exploit provides limited access, but the attacker uses a privilege escalation exploit to gain full control of the system*

4. Persistence Mechanisms:

- *To maintain access, attackers may install persistence mechanisms that ensure the malicious code remains active even after reboots or system updates*
- *Example: The RAT installs itself as a service that starts automatically with the system*



- *Tools Used in Exploitation*

1. Metasploit Framework:

- *Description:* A comprehensive penetration testing tool that includes a wide range of exploits and payloads. It allows attackers to test and execute exploits against target systems
- *Example:* Using Metasploit to exploit a vulnerability in a web application and execute a payload

2. Cobalt Strike:

- *Description:* A commercial penetration testing tool that provides advanced threat emulation capabilities. It includes features for exploiting vulnerabilities and conducting post-exploitation activities
- *Example:* Using Cobalt Strike to exploit a vulnerability and establish a command and control channel



3. **Exploit Kits:**

- *Description: Pre-packaged tools that automate the exploitation of vulnerabilities in web browsers and plugins. They are often used in drive-by download attacks*
- *Example: Using the RIG Exploit Kit to exploit a browser vulnerability and deliver malware*

4. **PowerShell Empire:**

- *Description: A post-exploitation framework that uses PowerShell scripts to execute exploits and maintain control over compromised systems*
- *Example: Using PowerShell Empire to execute a script that exploits a vulnerability and installs a backdoor*

5. SQLMap:

- *Description: An open-source tool that automates the process of detecting and exploiting SQL injection vulnerabilities*
- *Example: Using SQLMap to exploit a SQL injection vulnerability in a web application and extract sensitive data*

Cyber Attack

(Kill Chain)

Installation

- *Definition:*
 - *The attacker installs malware on the target system to maintain access*
 - *This often involves installing backdoors or other persistent mechanisms*
- *Technical Details:*
 - *The Installation phase is where the attacker ensures they can maintain access to the compromised system over time*
 - *This phase is critical for establishing a foothold within the target environment and enabling further malicious activities*

- *Here are the key technical aspects:*

1. Malware Deployment:

- *The attacker deploys malware onto the target system. This malware can take various forms, such as Trojans, rootkits, or spyware*
- ***Example:** The malicious code installs a remote access Trojan (RAT) on the employee's computer, allowing the attacker to control the system remotely*

2. Persistence Mechanisms:

- *To ensure the malware remains active even after system reboots or updates, attackers implement persistence mechanisms. These mechanisms can include modifying system files, creating scheduled tasks, or installing services*
- *Example: The RAT installs itself as a service that starts automatically with the system, ensuring it remains active even after a reboot*

3. Stealth Techniques:

- *Attackers often use techniques to hide the presence of the malware from detection by security tools. This can involve code obfuscation, encryption, or using rootkits to hide files and processes*
- *Example: The malware encrypts its payload and uses rootkit techniques to hide its files and processes from antivirus software*



4. Communication Channels:

- *The installed malware establishes communication channels with the attacker's command and control (C2) server. This allows the attacker to send commands and receive data from the compromised system*
- *Example: The RAT connects to the attacker's C2 server over an encrypted channel, enabling remote control and data exfiltration*

- *Tools Used in Installation*

1. Metasploit Framework:

- *Description: A comprehensive penetration testing tool that includes modules for deploying various types of malware and establishing persistence*
- *Example: Using Metasploit to deploy a RAT and configure it to start automatically with the system*



2. Cobalt Strike:

- *Description: A commercial penetration testing tool that provides advanced threat emulation capabilities, including malware deployment and persistence mechanisms*
- *Example: Using Cobalt Strike to deploy a beacon that maintains persistence and communicates with the C2 server*

3. Empire:

- *Description: A post-exploitation framework that uses PowerShell scripts to deploy malware and establish persistence on Windows systems*
- *Example: Using Empire to deploy a PowerShell-based backdoor that persists through system reboots*



4. Persistence Modules:

- *Description: Specific modules or scripts designed to establish persistence on compromised systems. These can be part of larger frameworks or standalone tools*
- *Example: Using a persistence module in Metasploit to create a scheduled task that runs the malware at system startup*

5. Rootkits:

- *Description: Tools that hide the presence of malware by modifying the operating system's kernel or using other stealth techniques*
- *Example: Deploying a rootkit to hide the files and processes associated with the installed malware*



Cyber Attack

(Kill Chain)

Command & Control (C2)

- *Definition:*
 - *The attacker establishes a **command and control channel** to communicate with the compromised system*
 - *This allows them to issue commands and control the malware*
- *Technical Details:*
 - *The Command & Control (C2) phase is where the attacker maintains communication with the compromised system*
 - *This phase is crucial for executing further malicious activities, such as **data exfiltration, lateral movement, and maintaining persistence***

Cyber Attack

(Kill Chain)

Command & Control (C2)

- *Here are the key technical aspects:*

1. Establishing the C2 Channel:

- *The malware on the compromised system initiates a connection to the attacker's C2 server. This connection can be established using various protocols and methods to avoid detection*
- *Example: The RAT on the compromised system connects to the attacker's C2 server over HTTP, HTTPS, or DNS to blend in with normal network traffic*

2. Communication Protocols:

- *Attackers use different communication protocols to establish and maintain the C2 channel. Common protocols include **HTTP/HTTPS, DNS, and custom protocols***
- ***Example:** Using HTTPS to encrypt the communication between the RAT and the C2 server, making it harder for network security tools to detect malicious traffic*

3. Encryption and Obfuscation:

- *To evade detection, attackers often encrypt and obfuscate the communication between the compromised system and the C2 server. This can involve using SSL/TLS, custom encryption algorithms, or encoding techniques*
- ***Example:** The RAT encrypts its communication with the C2 server using SSL/TLS, ensuring that the data transmitted is not easily readable by network monitoring tools*

4. Command Execution:

- *The attacker sends commands to the compromised system through the C2 channel. These commands can include instructions to download additional malware, execute specific tasks, or exfiltrate data*
- *Example: The attacker sends a command to the RAT to search for and exfiltrate sensitive files from the compromised system*

5. Maintaining Persistence:

- *The C2 channel allows the attacker to maintain control over the compromised system over time. This includes re-establishing the connection if it is disrupted and ensuring the malware remains active*
- *Example: The RAT is configured to reconnect to the C2 server periodically, ensuring that the attacker maintains control even if the initial connection is lost*



Cyber Attack

(Kill Chain)

Command & Control (C2)

- *Tools Used in Command & Control (C2)*

1. Cobalt Strike:

- *Description: A commercial penetration testing tool that provides advanced threat emulation capabilities, including C2 infrastructure. It allows attackers to create and manage C2 channels*
- *Example: Using Cobalt Strike to set up a C2 server and manage beacons on compromised systems*

2. Metasploit Framework:

- *Description: A comprehensive penetration testing tool that includes modules for establishing C2 channels. It supports various communication protocols and encryption methods*
- *Example: Using Metasploit to deploy a payload that connects to a C2 server over HTTPS*



3. Empire:

- *Description: A post-exploitation framework that uses PowerShell scripts to establish C2 channels. It supports encrypted communication and various persistence mechanisms*
- *Example: Using Empire to deploy a PowerShell-based backdoor that communicates with a C2 server over HTTPS*

4. Pupy:

- *Description: An open-source, cross-platform remote administration tool that supports encrypted C2 communication. It is designed for stealth and flexibility*
- *Example: Using Pupy to establish a C2 channel with a compromised system and execute commands remotely*



5. DNSCat2:

- *Description: A tool that uses DNS as a communication channel for C2. It allows attackers to send and receive data through DNS queries and responses*
- *Example: Using DNSCat2 to establish a covert C2 channel that communicates over DNS, bypassing traditional network security measures*

Cyber Attack

(Kill Chain)

Actions on Objectives (Exfiltration)

- *Definition:*
 - *The attacker achieves their objectives, which often involve data exfiltration, destruction, or further network compromise*
- *Technical Details:*
 - *The Actions on Objectives phase is where the attacker fulfills their primary goals*
 - *This phase can involve various malicious activities, such as data exfiltration, data destruction, or further compromising the network*

- *Here are the key technical aspects:*

1. Data Exfiltration:

- *Identification of Sensitive Data:* The attacker identifies valuable data on the compromised system or network. This can include intellectual property, financial records, personal information, or proprietary business information
 - *Example:* The attacker uses the RAT to search for files containing sensitive customer information
- *Data Collection:* The attacker collects the identified data, often compressing and encrypting it to avoid detection
 - *Example:* The attacker compresses the sensitive files into a single archive and encrypts it to prevent interception.



Cyber Attack

(Kill Chain)

Actions on Objectives (Exfiltration)

- *Data Transfer: The attacker transfers the collected data to an external location. This can be done using various protocols and methods to evade detection*
 - *Example: The attacker uses an encrypted HTTP connection to upload the compressed archive to a remote server*

2. Data Destruction:

- *Wiping Data: The attacker deletes or overwrites data to cause disruption or cover their tracks*
 - *Example: The attacker uses a script to overwrite critical system files, rendering the system inoperable*

Cyber Attack

(Kill Chain)

Actions on Objectives (Exfiltration)

- *Ransomware Deployment: The attacker encrypts the victim's data and demands a ransom for the decryption key*
 - *Example: The attacker deploys ransomware that encrypts all files on the victim's network and displays a ransom note*

3. Further Network Compromise:

- *Lateral Movement: The attacker moves laterally within the network to compromise additional systems and gather more data*
 - *Example: The attacker uses stolen credentials to access other systems on the network and exfiltrate additional data*

Cyber Attack

(Kill Chain)

Actions on Objectives (Exfiltration)

- *Establishing Additional Persistence*: The attacker installs additional backdoors or persistence mechanisms to maintain long-term access.
 - *Example*: The attacker deploys multiple backdoors on different systems to ensure continued access even if one is discovered.

• Tools Used in Actions on Objectives (Exfiltration)

1. Remote Access Trojans (RATs):

- *Description*: Malware that allows attackers to remotely control compromised systems. RATs are often used for data exfiltration and further network compromise
- *Example*: **DarkComet** is a popular RAT used for remote control and data exfiltration



2. Data Exfiltration Tools:

- *Description: Tools specifically designed to transfer data from the compromised system to an external location*
- *Example: Exfiltration Over Alternative Protocol (EOAP) tools, such as DNSExfiltrator, use DNS queries to exfiltrate data covertly*

3. Compression and Encryption Tools:

- *Description: Tools used to compress and encrypt data before exfiltration to avoid detection*
- *Example: 7-Zip can be used to compress and encrypt files before transferring them to a remote server*

4. File Transfer Tools:

- *Description: Tools used to transfer data from the compromised system to an external server*
- *Example: **cURL** is a command-line tool used to transfer data using various protocols, including HTTP, HTTPS, and FTP*

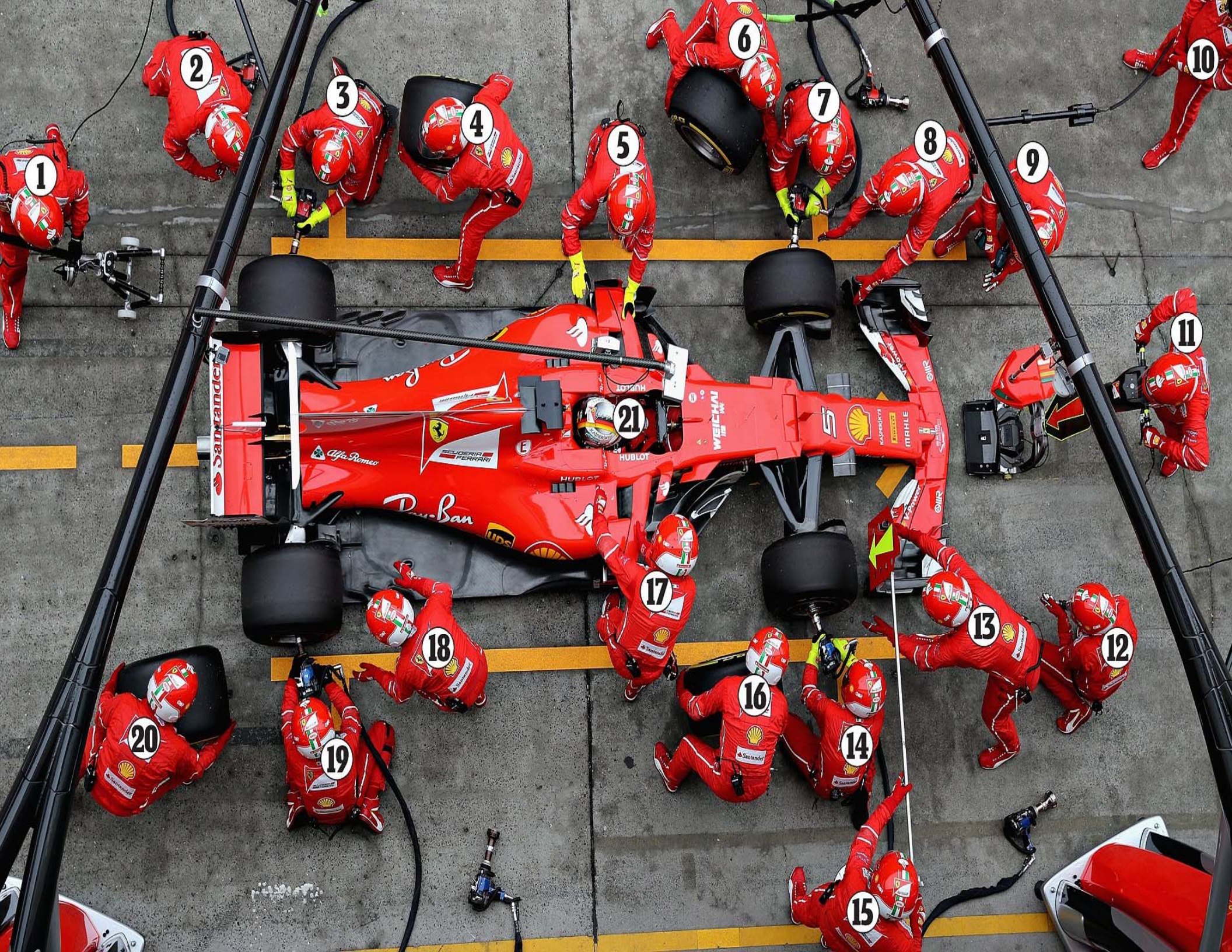
5. Lateral Movement Tools:

- *Description: Tools used to move laterally within the network and compromise additional systems*
- *Example: **Psexec** is a tool used to execute commands on remote systems, facilitating lateral movement*

6. Ransomware:

- *Description: Malware that encrypts the victim's data and demands a ransom for the decryption key*
- *Example: **WannaCry** is a well-known ransomware that encrypts files and demands payment in Bitcoin*





Questions

THANK YOU!



Ali Ali

Ali Ali